Sentinela Clandestino: Detecção de Aliciamento de Apostas Ilegais e Mitigação de Espelhos Mutantes na Borda via SLMs e Grafos de Ameaças

José Albérico Rocha da Silva[1]

Universidade Federal Rural de Pernambuco (UFRPE)
Departamento de Computação – Tópicos Avançados em Inteligência Artificial (2026.2)
Recife - PE, Brasil
jose.alberico@ufrpe.br
https://github.com/albericolx/Topicos_Avancados_IA

Abstract. Este relatório técnico formaliza a concepção, fundamentação bibliográfica e análise comparativa do projeto **Sentinela Clandestino (Vigilante de Espelhos e APKs)**, correspondente às etapas de Brainwriting Híbrido (`brw`) e Competidores e Contribuição (`cmp`) da Segunda Verificação de Aprendizagem (VA2) na disciplina Tópicos Avançados em Inteligência Artificial (UFRPE 2026.2). Diante da crise crônica de endividamento financeiro e proliferação de plataformas de apostas ilegais que burlam bloqueios governamentais via domínios espelhos mutantes e distribuição clandestina de APKs nas redes sociais, propõe-se uma arquitetura de proteção reativa na borda (*on-device*). O sistema intercepta tentativas de redirecionamento para URLs externas e transferências de executáveis no momento do clique, empregando um Modelo de Linguagem de Pequeno Porte (SLM) quantizado localmente para análise semântica da página de pouso e inspeção de manifestos de aplicação, orquestrado por agentes locais via *Model Context Protocol* (MCP) que consultam resumos de grafos de DNS passivo. A contribuição é rigorosamente delimitada frente a dez ferramentas comerciais e dez artigos científicos de ponta, assumindo honestamente perdas operacionais categóricas em latência de redirecionamento (100–300ms), consumo contínuo de memória e escala de produção frente a filtros estáticos leves.

Keywords: Apostas Clandestinas · Engenharia Social · Small Language Models · On-Device AI · Grafos de DNS Passivo · Segurança Mobile · AI for Good.

1 Introdução

A proliferação de plataformas de apostas digitais (*bets*) estabeleceu uma das mais severas crises socioeconômicas e de vulnerabilidade financeira no Brasil contemporâneo. Conforme estimativa oficial do Banco Central do Brasil (BACEN) divulgada em agosto de 2024, o volume financeiro global movimentado

por pessoas físicas em plataformas de apostas atingiu cerca de **R$ 20,8 bilhões por mês** via Pix. Desse montante astronômico, a Secretaria de Prêmios e Apostas do Ministério da Fazenda (SPA/MF) e órgãos de segurança pública estimam que o **mercado clandestino e não regulamentado represente entre 30% e 50% dos depósitos** (drenando de R$ 6 a R$ 10 bilhões mensais para redes que operam à margem do licenciamento estatal e fora de qualquer supervisão jurídica). A subsequente repressão governamental, que notificou mais de 2.000 sites para bloqueio junto à Anatel em outubro de 2024, não encerrou as operações ilegais; pelo contrário, intensificou o recurso à camuflagem digital contínua.

Nesse submundo, operadores clandestinos distribuem hiperlinks em redes sociais e mensageria (Instagram, TikTok, Telegram e WhatsApp) que redirecionam vítimas para domínios espelhos mutantes de registro efêmero (gerados via DGA sob extensões como `.xyz` ou `.top`) e induzem a instalação de binários fora da loja oficial (*side-loading* de APKs piratas). Além do endividamento, essa prática expõe o cidadão a golpes deliberados de **retenção ilícita de saques** (plataformas que aceitam depósitos via Pix mas congelam a conta na tentativa de resgate de prêmios) e à infecção por *trojans* bancários camuflados em APKs recompilados em massa [2].

As defesas computacionais convencionais enfrentam limitações estruturais críticas frente a essa infraestrutura mutante:

1. **Falha das Listas Estáticas e Bloqueios Simples:** Uma lista negra de chaves Pix ou de domínios bloqueados no teclado é ineficaz contra o crime organizado. Os operadores utilizam algoritmos de geração de domínios (DGA) que colocam espelhos no ar minutos antes das campanhas. Da mesma forma, os depósitos não usam uma chave Pix fixa, mas APIs de provedores de serviço de pagamento (PSPs) que geram QR Codes dinâmicos atrelados a contas rotativas de laranjas;
2. **Cegueira Semântica e Falsos Positivos:** Regras simples de filtragem de texto ou bloqueios genéricos de downloads punem indiscriminadamente o usuário ou falham diante de ofuscação léxica (*leetspeak*) e promessas de ganhos fáceis camufladas em linguagem informal;
3. **Inviabilidade de Escrutínio de Feeds Fechados:** A arquitetura de segurança do Android impõe *sandboxing* rígido e conexões criptografadas (*TLS pinning*), tornando tecnicamente impossível que um aplicativo terceiro leia feeds privados de redes sociais em tempo real.

Para resolver essa lacuna, propõe-se o **Sentinela Clandestino (Vigilante de Espelhos e APKs)**, concebido no âmbito das atividades da Segunda Verificação de Aprendizagem (VA2). O sistema atua na camada legítima de redirecionamento do sistema operacional móvel: ao detectar tentativas de abertura de links externos ou transferência de APKs desconhecidos, dispara um Modelo de Linguagem de Pequeno Porte (*Small Language Model* – SLM, 1B–3B em INT4) executado integralmente no aparelho (*on-device*) [3], articulado a agentes locais via *Model Context Protocol* (MCP) que consultam resumos de grafos de DNS passivo [5].

O mecanismo ancora-se no **interesse próprio e egoísta do próprio apostador**: em vez de impor censura moral coercitiva (que faria o jogador desinstalar o app), o Sentinela expõe evidências técnicas de fraude contratual (risco crítico de bloqueio de saque, presença de *trojan* bancário no binário e envolvimento de intermediadoras fantasmas investigadas pelo Banco Central), protegendo o patrimônio do cidadão pela sua vontade direta de não ser enganado.

2 Trabalhos Relacionados e Matriz de Contribuição

A delimitação da fronteira tecnológica do Sentinela Clandestino fundamenta-se na análise comparativa de dez ferramentas de mercado e dez artigos científicos recentes, avaliados segundo as dimensões de Cenário, Usuário, Problema e Tecnologia (CUPT). A partir desse levantamento, selecionaram-se os três competidores de mercado e as três referências bibliográficas mais próximas.

2.1 Competidores de Mercado e Literatura Mais Próximos

- **Trend Micro Check:** Constitui o concorrente mais direto na interação móvel, utilizando IA para analisar prints e mensagens suspeitas. Entretanto, depende de ação voluntária e manual do usuário, processa dados na nuvem corporativa e não intercepta ativamente espelhos mutantes no ato do redirecionamento;
- **Gamban:** Referência global em autoexclusão de apostas digitais com bloqueio rígido em nível de rede local (via VPN loopback). Contudo, opera estritamente sobre listas estáticas de domínios consolidados, sendo totalmente ineficaz contra domínios efêmeros e APKs clandestinos;
- **Netcraft Mobile:** Solução líder em proteção contra ataques de *phishing* e *smishing* com inspeção no momento do toque, mas sem compreensão de engenharia social focada na linguagem informal de aliciamento de apostas no Brasil;
- **Muzakir et al. (2025) [4]:** Empregam CNNs e AutoML sobre 15.286 sentenças extraídas de anúncios de apostas em redes sociais (92,80% de acurácia). Contudo, o sistema foi desenhado para moderação centralizada na nuvem voltada à língua indonésia, não atuando no terminal móvel;
- **The PRECOM-SM Corpus (Álvarez-Ojeda et al., 2025) [1]:** Primeiro corpus de referência no COLING 2025 para identificar marcadores de dependência de apostas em redes sociais hispânicas, limitando-se à análise descritiva de comunidades sem mecanismo ativo de contenção de rede ou APKs;
- **Nabeel et al. (2020) [5]:** Propõem algoritmos de inferência em grafos de DNS passivo (pDNS) no *ACM TOPS* para rastrear infraestruturas de domínios maliciosos antes de ativação massiva. O método depende de telemetria corporativa de provedores de internet, não operando no smartphone do cidadão.

Table 1. Matriz comparativa de competidores e contribuição (✓: faz integralmente; ►: faz em parte; ×: não faz; ?: não reportado). Os três últimos eixos evidenciam onde a nossa proposta perde categoricamente (×).

Trabalho / Solução	**Eixo 1** Intercep. Redirec.	**Eixo 2** Audita APK	**Eixo 3** Espelhos Grafos	**Eixo 4** Cláusulas Calote/Saque	**Eixo 5** Dados Celular	**Eixo 6** Latência < 50ms	**Eixo 7** Baixo Cons. Bat/RAM	**Eixo 8** Prontidão Produção
Trend Micro Check	×	×	►	►	×	✓	✓	✓
Gamban	×	►	×	×	✓	✓	✓	✓
Netcraft Mobile	►	×	►	×	×	✓	✓	✓
Muzakir et al. (2025) [4]	×	×	×	✓	×	?	?	×
Álvarez-Ojeda et al. (2025) [1]	×	×	×	✓	×	?	?	×
Nabeel et al. (2020) [5]	×	×	✓	×	×	?	?	×
Sentinela Clandestino	✓	✓	✓	✓	✓	×	×	×

2.2 Matriz Comparativa de Eixos e Evidências Empíricas

A Tabela 1 formaliza a matriz comparativa de 8 eixos operacionais, confrontando a proposta do Sentinela Clandestino com os seis trabalhos mais próximos. Seguindo o princípio de rigor metodológico da disciplina, o modelo proposto assume honestamente a perda em três eixos críticos de engenharia.

2.3 Declaração Canônica da Contribuição

Com base na combinação única de quadrantes em que a solução atua de forma diferenciada, a contribuição científico-tecnológica é expressa formalmente como:

> *"O Sentinela Clandestino correlaciona a semântica de persuasão e regras de saque da página de pouso com a topologia de infraestrutura de espelhos e APKs diretamente na borda do smartphone, e por isso expõe fraudes de calote e malwares no momento do redirecionamento com total privacidade local, o que nem os filtros de rede estáticos (Gamban/Netcraft) nem os classificadores em nuvem (Muzakir/Álvarez-Ojeda) conseguem realizar isoladamente."*

O trabalho mais próximo é o **Trend Micro Check**, que analisa links e capturas de tela com modelos de IA na nuvem; todavia, ele falha porque depende da proatividade manual da vítima em enviar o conteúdo e avalia apenas reputação genérica, falhando em auditar cláusulas de retenção de saque em espelhos mutantes e em inspecionar manifestos de APKs piratas no momento do clique.

3 Arquitetura Sistêmica e Metodologia

A arquitetura do Sentinela Clandestino foi desenhada para operar sob as restrições rígidas de segurança, memória e consumo de energia típicas de dispositivos móveis populares, rejeitando regras heurísticas cegas (como bloqueios estáticos genéricos de arquivos ou listas fixas de domínios) e articulando três componentes de IA na borda.

3.1 Camada de Interceptação e Triagem de Eventos na Borda

Em vez de tentar violar o isolamento de processos de redes sociais proprietárias (inviabilizado pelo *sandboxing* do Android), o sistema atua na transição legítima de contexto do sistema operacional:

1. **Interceptação de Redirecionamento (*Intent Interception*):** Captura requisições de abertura de links externos despachadas a partir de navegadores embutidos (*Custom Tabs*) ou mensageiros instantâneos;
2. **Gatilho de Download de Binários:** Detecta o início de transferências de arquivos executáveis com extensão `.apk` provenientes de fontes desconhecidas fora da loja Google Play.

3.2 Inferência Semântica On-Device via SLM Quantizado

Ao interceptar a página de destino (*landing page*), o texto textual renderizado é submetido a um modelo de linguagem de pequeno porte quantizado em 4-bit (INT4) baseado na arquitetura MobileLLM [3]. O modelo avalia a presença de padrões de linguagem persuasiva, promessas de ganhos fáceis (e.g., termos como "banca", "alavancagem", "bug do tigrinho") e audita as cláusulas contratuais de pagamento em busca de armadilhas de **retenção ilícita de saques** (*rollovers* abusivos e cobrança de taxas prévias para liberação de prêmios), alcançando alta capacidade discriminativa com pegada de memória inferior a 500 MB de RAM e tempo de inferência abaixo de 250 ms.

3.3 Inspeção de Código Polimórfico e Correlação em Grafos

Quando o evento envolve um pacote de aplicação Android:

1. **Análise Semântica do Manifesto e Bytecode:** Como os criminosos recompilam APKs dinamicamente para alterar assinaturas SHA-256 e ofuscar chamadas de API (*automated mass malware factory*) [2,6], o SLM analisa a discrepância funcional entre a descrição do app e as permissões críticas requisitadas (acesso a SMS para interceptação de 2FA, sobreposição de tela bancária e leitura de *clipboard*);
2. **Agente MCP e Consulta a Grafos de Ameaças:** Por meio de um agente orquestrado via *Model Context Protocol* (MCP), o sistema consulta um *digest* comprimido (baseado em filtros de Bloom e grafos de resolução passiva de DNS [5]) para correlacionar o domínio do servidor com clusters históricos de operadores clandestinos e laranjas financeiros.

Em vez de impor um bloqueio opaco que gere frustração e leve à desinstalação do sistema, o Sentinela Clandestino apresenta um **Painel de Evidências de Risco**: comprova ao apostador se a plataforma possui indícios de não pagamento de saques, código espião ou chave Pix vinculada a contas sob investigação de lavagem de dinheiro, canalizando o interesse do próprio usuário em não ser vítima de estelionato.

4 Considerações Finais e Trade-offs de Engenharia

A viabilização do Sentinela Clandestino impõe a aceitação explícita de compromissos técnicos de engenharia de software e sistemas operacionais, evitando concessões complacentes:

1. **Latência de Redirecionamento (**100–300**ms vs.** $<$ 50**ms):** Filtros estáticos de DNS ou VPN (como Gamban e Netcraft) operam com descarte quase instantâneo de pacotes ($<$ 10ms). A execução de uma passagem direta (*forward pass*) de um SLM quantizado e a consulta ao grafo local introduzem uma latência perceptível de até 300 milissegundos durante o clique externo, configurando um custo deliberado em prol da análise contextual profunda;
2. **Consumo Energético e Alocação de Memória:** Manter um modelo de linguagem residente na memória de smartphones de entrada causaria o encerramento do processo pelo *Low Memory Killer* (LMK) do Android. Portanto, a arquitetura adota ativação estritamente orientada a eventos, permanecendo inativa durante a navegação cotidiana e ativando o processador neural (NPU/CPU) apenas em eventos de clique externo ou download;
3. **Maturidade de Validação em Escala:** Enquanto produtos comerciais possuem bases de milhões de usuários e certificação regulatória, o Sentinela Clandestino posiciona-se como uma investigação tecnológica de vanguarda voltada para o bem social (*AI for Good*).

Em síntese, enquanto as soluções existentes tentam conter o avanço das fraudes mediante tabelas fixas de endereços ou delegando a privacidade a servidores corporativos na nuvem, o Sentinela Clandestino articula a triagem semântica no aparelho com a inteligência de grafos de infraestrutura criminosa, oferecendo proteção em tempo real sem comprometer a soberania dos dados do cidadão.

References

1. Álvarez-Ojeda, P., Cantero-Romero, M.V., Semikozova, A., Montejo-Ráez, A.: The PRECOM-SM corpus: Gambling in spanish social media. In: Proceedings of the 31st International Conference on Computational Linguistics (COLING 2025). pp. 17–28. Association for Computational Linguistics (2025), https://aclanthology.org/2025.coling-main.2/
2. Li, X., Zhang, Y., Wang, H., Chen, S., Li, X.: Automated mass malware factory: The convergence of piggybacking and adversarial example in Android malicious software generation. In: Proceedings of the Network and Distributed System Security Symposium (NDSS 2025). Internet Society (2025), https://www.ndss-symposium.org/ndss-paper/automated-mass-malware-factory/
3. Liu, Z., Zhao, C., Iandola, F., Lai, C., Tian, Y., Fedorov, I., Xiong, Y., Chang, E., Shi, Y., Krishnamoorthi, R., Lai, L., Chandra, V.: MobileLLM: Optimizing sub-billion parameter language models for on-device use cases. In: Proceedings of the 41st International Conference on Machine Learning (ICML 2024). Proceedings of Machine Learning Research, vol. 235, pp. 31737–31757. PMLR (2024), https://proceedings.mlr.press/v235/liu24ce.html

4. Muzakir, A., Ependi, U., Suyanto, Prasetyaningrum, P.T., Alfiansyah, M., Rosi, V.T.: Text-based detection of online gambling advertisements on social media using AutoML and CNN. In: Proceedings of the 2025 2nd International Conference on Information System and Information Technology (ICISIT). pp. 1–6. IEEE (2025). https://doi.org/10.1109/ICISIT.2025.10842131
5. Nabeel, M., Khalil, I.M., Guan, B., Yu, T.: Following passive DNS traces to detect stealthy malicious domains via graph inference. ACM Transactions on Privacy and Security **23**(4), 17:1–17:29 (2020). https://doi.org/10.1145/3401897
6. Zhang, Y., Chen, S., Li, X., Li, X.: Fighting fire with fire: Adversarial Android malware detection via continuous gradient optimization. In: Proceedings of the 34th USENIX Security Symposium (USENIX Security 2025). USENIX Association (2025), https://www.usenix.org/conference/usenixsecurity25/presentation/zhang-yinyuan